

Inventre

Data Protection & Privacy

What personal data Inventre holds, why, where it flows, who can see it, how long it is kept, and what India's Digital Personal Data Protection Act 2023 requires of us, with the gaps and the plan to close them.



DOCUMENT	DATE	STATUS	OWNER
DPP v1.1	24 September 2026	Baseline, for legal review	Inventre Engineering

Written from the production database schema, code and operations as they are today. The legal sections summarise the Act in plain language for engineers and managers; they are not legal advice and should be confirmed by counsel before being relied on externally.

Contents

01	Summary and the decisions we need	3
02	Roles: who is responsible for what	5
03	What personal data we hold (inventory)	7
04	Where the data flows	11
05	Who can see it (access)	13
06	How long we keep it (retention)	15
07	How it is protected (security measures)	18
08	What the DPDP Act 2023 requires, and where we stand	19
09	Children's data	23
10	Rights of parents and how we serve them	25
11	Breach response	26
12	Findings and action plan	28

Revision history

Version	Date	Author	Change
1.0	2026-09-23	Engineering	First baseline: inventory from the live schema, flows, access, retention as practised, DPDP gap assessment, action plan P-01 ... P-14.
1.1	2026-09-24	Engineering	Rectification pass: P-01, P-05, P-06, P-08, P-09, P-12 closed in code; P-02 decided (keep public links); retention job live in count-only mode with three automatic rules; three new findings P-15...P-17; inventory corrected (date of birth, student mobile/e-mail are in use).

01 Summary and the decisions we need

Inventre holds personal data about roughly 15,000 families: parents' phone numbers, names and addresses; children's names, schools, grades, dates of birth and sizes; order and payment records; and, through the fee ledger, the fee and receipt history of about 12,000 students across eight school branches. Almost all of it concerns children. Under the Digital Personal Data Protection Act 2023 (DPDP Act) Inventre is a **Data Fiduciary** for the storefront data and, for the fee ledger, acts on behalf of the schools.

Where we stand in one table

Area	Status	Plain-language meaning
Knowing what we hold	Done	Section 3 lists every table and field with personal data. Nothing is hidden.
Security of the data	Good	Encrypted in transit, role-based access, audit trail, encrypted off-host backups, secrets rotated this month (see the HLD security section).
Consent and notice to parents	Partial	Parents accept terms at first login (recorded), but there is no privacy notice that says in plain words what we collect and why, and no separate consent for a child's data.
Retention	Partial	A nightly retention job now reports what each rule would delete; three rules already act automatically (OTP codes wiped after 24 h, OTP log rows after 90 days, parents inactive for 3 years anonymised). The remaining rules stay count-only until the owner approves Section 6.
Parents' rights (access, correction, erasure)	Partial	Parents can download a copy of their data and file a deletion request from the account page; the grievance officer is published on /privacy but not yet named.
Breach handling	Done	Written procedure with notification templates: docs/runbooks/breach-response.md .

Area	Status	Plain-language meaning
Third parties (processors)	Partial	Seven external systems receive personal data. Only the payment gateway has a formal contract on record.
Two concrete defects found while writing v1.0	Partial	OTP codes are now encrypted at rest and revealed only with a key phrase, every reveal logged (P-01 closed). Exchange and concern photos stay on unguessable public links by owner decision, because the fulfilment ERP opens them directly (P-02 decided; a 180-day clean-up rule exists in the retention job).

Decisions the owner needs to take

1. **Name the grievance officer.** The officer block and a 7-working-day response target are published on /privacy; the name and e-mail are still blank. The Act requires a named contact.
2. **Approve the rest of the retention schedule** in Section 6. Three rules are approved and already run (OTP codes, OTP log rows, inactive parents); the other rules are counted nightly and become automatic once approved (`RETENTION_APPLY=1`).
3. **Have counsel review the privacy notice** now published at /privacy (version 2026-09-24, outline in Section 8.3). It is live; the review is pending.
4. **Confirm the consent model for children's data:** the notice (section 5) now states that the parent account is the verifiable parental consent. Confirm this with counsel, or ask for an explicit per-child consent step (deferred, see P-11).
5. **Sign processor agreements** with the Audit ERP operator and the SMS vendor, and confirm the terms already in place with CCAvenue, MyClassBoard, Cloudflare and Microsoft.
6. **Decided (2026-09-24): photos stay public.** Exchange and concern photos remain on unguessable public links because the fulfilment ERP opens them directly (P-02). The retention job blanks the references 180 days after a case closes once that rule is switched on.

02 Roles: who is responsible for what

Role (DPDP term)	Who, for Inventre	Responsibility
Data Principal	The parent or guardian; for a child, the parent acts on the child's behalf	The person the data is about. Has rights of access, correction, erasure, grievance and nomination.
Data Fiduciary	Inventre (the company operating inventre.in)	Decides why and how personal data is processed. Carries the obligations: notice, consent, security, breach notification, erasure, grievance handling, and for children, verifiable parental consent.
Data Fiduciary or Processor for the fee ledger	The schools decide the purpose; Inventre imports and displays	For MyClassBoard fee and receipt data the school is the fiduciary and Inventre processes on its behalf. This should be written into the school agreements.
Data Processors	Audit ERP operator, CCAvenue, Arihant Global (SMS), Microsoft 365 (SMTP, backups), Cloudflare R2 (media), GitHub (code only), MyClassBoard (source system)	Process on Inventre's instructions. Inventre remains answerable for them and needs written terms.
Grievance Officer	Not yet appointed	Receives complaints and rights requests, answers within the statutory period, escalates to the owner.
Consent Manager	Not used	An optional registered intermediary under the Act. Not needed for Inventre's scale today.

INTERNAL OWNERS

Accountable: the company owner (sunith@inventre.in). **Operational:** Inventre Engineering for systems and this document; the operations lead for handling requests from parents and schools; the fee-desk lead for the fee ledger. Alerts go to it@inventre.in.

03 What personal data we hold (inventory)

Every field below exists in the production database today (schema of 23 September 2026). Sensitivity: **High** could cause real harm if exposed (children's identifiers, contact details, financial records, credentials); **Medium** personal but low harm alone; **Low** operational.

3.1 Parents and guardians

Table	Personal fields	Level	Why we hold it
parents	phone (login identity), name, email, password hash, notes, tags, lifetime value, order count, last login, terms accepted (version + time), language	High	Account, login, order history, support
guardians, student_guardian_links	guardian name, mobile, alternate number, email, date of birth, relation to the child, raw school-system record	High	Which adults may act for which child; login by any linked phone
addresses, student_addresses	receiver name and phone, address lines, city, pincode, landmark, GSTIN and company name (B2B), raw school record	High	Delivery and invoicing
communications, order_notifications	subject, body and recipient of every message sent to a parent	Medium	Proof of what was communicated
contact_submissions, concerns, concern_messages	name, phone, email, free-text description, photos (URL), assigned staff	Medium	Support tickets and public contact form

3.2 Children (students)

Table	Personal fields	Level	Why we hold it
<code>students</code>	full name (first, middle, last), school, class, section, grade, enrolment number, date of birth , blood group , gender, house colour, medium, curriculum, joining date, shoe / shirt / trouser sizes and size overrides, student e-mail and mobile (where the school recorded one), profile picture URL , verification flags, raw school-system record	High	Catalogue scoping (school + grade), sizing, order attribution, school roster sync. Date of birth is shown on the parent's account page; student mobile and e-mail are sent to the fulfilment ERP and used by admin search.
<code>student_siblings</code>	links between children of one family	Medium	One account for all siblings
<code>mcb_students</code>	the MyClassBoard roster record for each fee-paying student (name, enrolment, class, section, status, guardian contact, raw feed)	High	Fee ledger console

OBSERVATION

Blood group and profile picture have no reader anywhere outside the admin student editor; date of birth, student mobile and e-mail **are** used (account page, ERP payload, admin search). v1.0 said all four were unused; corrected. Decision: keep the fields; stop them leaking. Date of birth now leaves the server only for the account page (`/api/auth/me?include=dob`), and the public support portal masks the guardian's mobile to its last four digits unless the visitor searched by that very number (P-05 closed).

3.3 Orders, payments, fees

Table	Personal fields	Level	Why we hold it
<code>orders</code> , <code>order_items</code>	who ordered what for which child, shipping and billing address snapshots, grade and school snapshots, notes, cancellation reason	Medium	Fulfilment, returns, accounts (GST law requires invoice records for 8 years)

Table	Personal fields	Level	Why we hold it
payments, invoices	gateway references, amounts, payment method, raw gateway response, customer GSTIN, invoice addresses. No card or bank details: payment happens on CCAvenue's page.	Medium	Reconciliation, GST invoicing
returns, missing_item_claims	reason, free-text notes, photos uploaded by the parent (URL), pickup date, staff decisions	Medium	Exchange and missing-item handling
mcb_fee_payments, mcb_fee_transactions	per student: fee heads billed, amounts due and paid, concessions, receipt numbers and dates	High	Fee ledger and receivables ageing for the schools (financial data about a family)
reviews, wishlists, loyalty_ledger, gift_cards	parent id linked to opinions, saved items, points, gift card codes	Low	Engagement features (barely used)

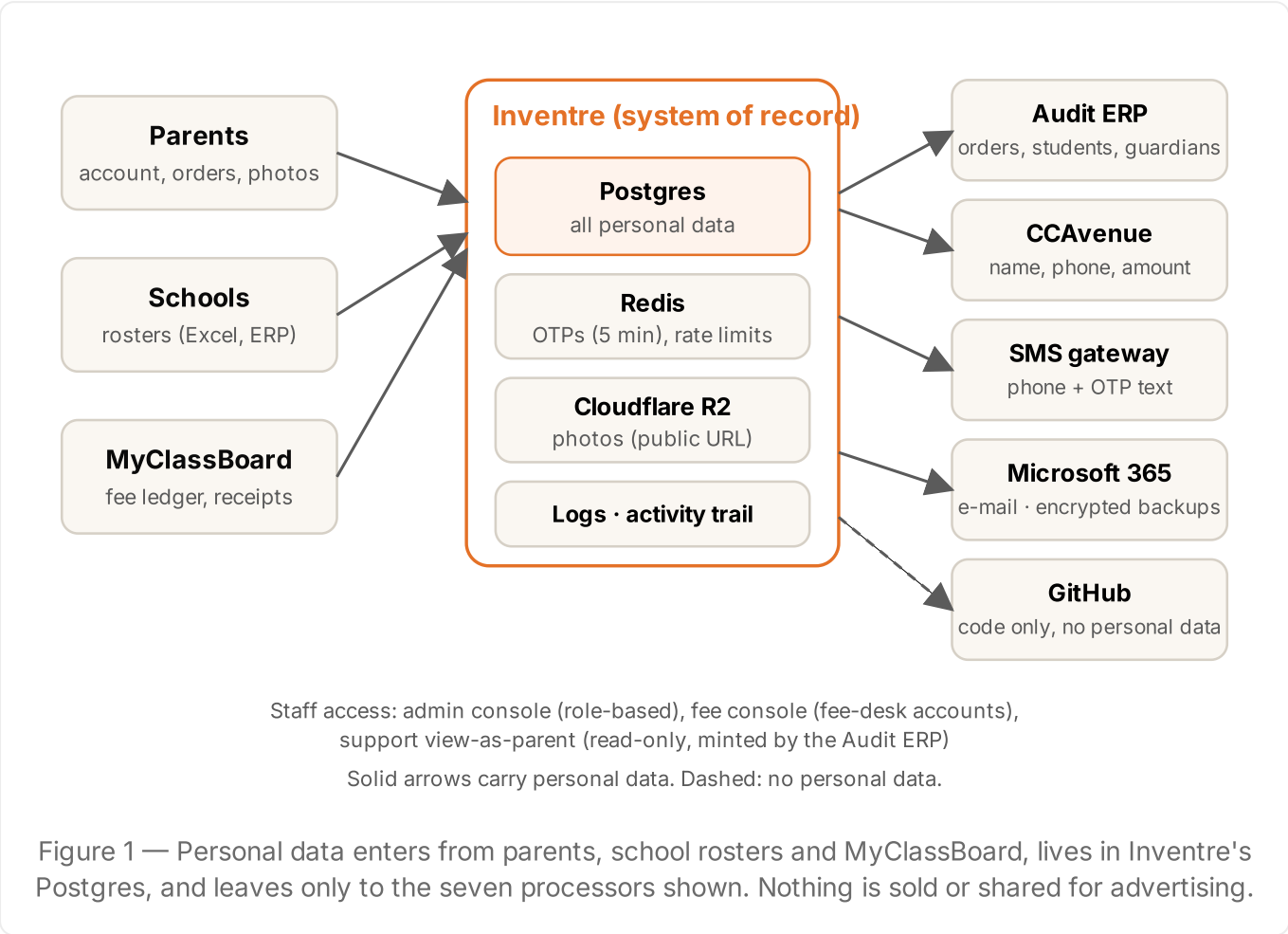
3.4 Logs and technical data

Table / store	Personal fields	Level	Why we hold it
otp_logs	phone, purpose, the OTP code (encrypted with AES-256-GCM, wiped after 24 hours), gateway transaction id, error, IP address	High	Diagnosing SMS delivery. A staff member with the write permission can reveal one code with the key phrase; each reveal is written to the activity log (P-01).
activity_log, audit_log	which staff member changed what, with before/after values, IP address	Medium	Accountability for admin actions; contains parents' and children's data inside the diffs
storefront_events	parent id, request path, error message and stack for failures	Low	Reliability
Redis	OTP codes (5-minute expiry), rate-limit counters keyed by phone and IP, cart mirror	Medium	Login flow; expires automatically

Table / store	Personal fields	Level	Why we hold it
Cloudflare R2 (media bucket)	product images (not personal) and parents' exchange / concern photos (public by decision, unguessable links; P-02)	Medium	Media delivery; the fulfilment ERP opens the photos directly. Bucket location hint: APAC (Cloudflare R2, confirmed 2026-09-24)
Backups (Microsoft 365, SharePoint)	everything above, encrypted before upload	High	Disaster recovery; only two keys unlock it
Web server and application logs	IP addresses, request paths (may include order ids), user agents	Low	Operations; rotated by the OS
users (staff)	staff name, email, password hash, role, last login	Medium	Admin accounts

Not held anywhere: card numbers, bank accounts, UPI ids, government identity numbers, biometric data, location tracking, behavioural advertising profiles.

04 Where the data flows



Recipient	What is sent	Why	Terms on record
Audit ERP (in-house, separate host)	Orders with child's name, grade, school, enrolment; guardian names and phones; addresses; exchange, missing and concern requests	Fulfilment and call centre	None written (same company group; still needs an internal data-sharing note)
CCAvenue	Order id, amount, payer name, phone, e-mail, billing address	Payment	Merchant agreement (2026)
Arihant Global (SMS)	Phone number and OTP text	Login	Commercial terms only
Microsoft 365	E-mails to parents and staff (SMTP); encrypted backup files	Communication, disaster recovery	Microsoft Online Services terms (company tenant)
Cloudflare R2	Uploaded photos; product images	Media storage and delivery	Cloudflare terms

Recipient	What is sent	Why	Terms on record
MyClassBoard	Inventre only <i>reads</i> from it; nothing is sent back	Fee ledger	Via the schools' contracts
GitHub	Source code only	Code backup	GitHub terms; personal data is kept out by the repository hygiene test

No personal data leaves India except to Microsoft 365, Cloudflare and GitHub, whose data-centre regions are set by the tenant and account configuration. The DPDP Act permits transfers except to countries the government restricts by notification; none is restricted as of this writing. The R2 bucket's location hint is APAC (confirmed 2026-09-24). Confirm the Microsoft tenant's data location in the admin centre (it is usually India for Indian tenants; P-14).

05 Who can see it (access)

Population	Mechanism	Sees
Parents	Storefront login (OTP or password), <code>inv_session</code> cookie	Only their own family: every read is scoped to the family graph; a co-guardian outside it gets a 404, never a different parent's data.
Inventre operations (<code>super</code> , <code>ops</code>)	Admin console, per-page read/write permissions from roles plus per-user grants	All families and orders they are permitted to; every change is written to the activity log with before and after values.
School administrators (<code>school_admin</code>)	Admin console, read-only, scoped to their school	Their school's students and orders only.
Fee desk (<code>fees-viewer</code> , <code>fees-admin</code>)	Separate fee-console login and cookie; admin pages reject the fee cookie	Fee ledger, receipts, ageing for the schools in scope; no storefront or order data.
Audit ERP call-centre agents	"View as parent": a short-lived read-only session minted by the ERP; every write is blocked at the edge; the mint is logged	Exactly what the parent sees, nothing more, to work a ticket.
Engineering (root on the server)	SSH with keys only; production database reads are permitted for analysis, writes by the owner	Everything. This is the highest-risk access and the reason the host was hardened after the June 2026 compromise.
Backups	Encrypted before upload; two keys plus a kit passphrase held by the owner	Anyone in the SharePoint site sees only opaque files.

LEAST PRIVILEGE IN PRACTICE

All 39 admin sections carry a permission gate and 141 admin API routes require a named permission; an automated test fails the build if either regresses. Staff names are stripped from parent-facing tracking timelines. Fee-desk accounts cannot reach the admin console at all.

06 How long we keep it (retention)

Until 24 September 2026 nothing was deleted except expired carts and Redis keys. The Act requires erasure once the purpose is served, unless another law requires retention. Since 2026-09-24 a nightly job (`/api/cron/data-retention` , 02:40 IST) evaluates every rule below. Three rules act automatically; the rest only report the number of rows they would touch until the owner switches them on (`RETENTION_APPLY=1`). `?dry=1` previews all counts. The schedule is otherwise still a proposal for the owner to approve.

Data	Today	Proposed	Basis
OTP codes in <code>otp_logs</code>	Encrypted; wiped after 24 h (automatic)	Unchanged (P-01 closed)	Only needed to diagnose a delivery within the day
OTP log rows (phone, outcome, error)	90 days (automatic)	Unchanged	Only needed to diagnose SMS delivery
Redis OTP and rate-limit keys	5 min / 1 h	Unchanged	Already expires
Orders, invoices, payments	Forever · counted nightly, not yet deleted	8 years from the financial year end, then anonymise the parent link and address	GST and Income-tax record-keeping
Carts	7 days	Unchanged	Already automatic

Data	Today	Proposed	Basis
Parent accounts with no active student and no order in 3 years	Anonymised automatically (name, e-mail, phone, password replaced; guardian-link rows keep the old phone; open)	Add the 30-day notice before anonymising; extend to the guardian-link rows	Purpose served (children have left the schools)
Students who left a school (roster shows leaver)	Forever, flagged · counted nightly, not yet deleted	Keep for 1 year after leaving for exchange and fee follow-up, then anonymise name and identifiers; orders keep an anonymised link	Purpose served
Imported child fields (date of birth, blood group, student mobile, picture)	Held; date of birth scoped to the account page, mobile masked on the public portal	Keep (P-05 closed); purposes stated in Section 3	Account page, ERP payload, admin search
Exchange, missing and concern photos	Forever, public URL · counted nightly, not yet deleted	Stay public by decision (P-02); blank the photo references 180 days after the request closes (rule R5); bucket objects not yet deleted	Only needed while the case is open

Data	Today	Proposed	Basis
Activity and audit logs	Forever · counted nightly, not yet deleted	2 years online, then archive to the encrypted backup only	Accountability; contains personal data in diffs
Fee ledger imports (mcb_*)	Refreshed nightly, never pruned · counted nightly, not yet deleted	Keep current + 3 academic years ; older rows deleted	Schools' own retention governs; Inventre is a processor
Communications and notifications	Forever · counted nightly, not yet deleted	2 years	Proof of what was sent
Web server logs	OS rotation (weeks)	Unchanged, 90 days maximum	Operations
Backups	30 days point-in-time, 14 daily, monthly, 12 months	Unchanged; deletions above propagate as backups age out	Disaster recovery

07 How it is protected (security measures)

IN TRANSIT

- TLS everywhere (Let's Encrypt), HSTS, security headers verified after every deploy
- Partner links signed (HMAC) or encrypted (CCAvue AES); replication and internal links inside a private Docker network

AT REST

- Passwords hashed with bcrypt; no card data ever stored
- Backups encrypted on the server before leaving it; configuration encrypted inside snapshots
- Database and Redis reachable only on the host; Redis password-protected

ACCESS CONTROL

- Four separate session types; role and per-page permissions; family-graph scoping for parents
- Read-only support impersonation with edge enforcement
- Key-only SSH, fail2ban, firewall on Docker ports

ACCOUNTABILITY

- Activity log for every admin change; OTP log; 5xx telemetry
- Every production build carries its commit; a monitor detects a foreign build or lost security headers and e-mails
- All production secrets rotated in September 2026 after the June compromise (database password pending)

KNOWN WEAKNESSES RELEVANT TO PERSONAL DATA

(1) Closed: OTP codes in `otp_logs` are now encrypted, and a reveal needs the key phrase and is logged (P-01). (2) Parents' photos stay on unguessable public links by owner decision, because the fulfilment ERP opens them directly; anyone with a link can read the photo (P-02). (3) Root access on the server sees everything, and one root compromise happened in June 2026; the remediation is in the HLD, the remaining item is the database password rotation (P-03). (4) New: the public support portal's concern photo upload needs no login, so anyone can push files into our bucket (P-16). (5) New: blocking a parent account does not end a session that is already open (P-17).

08 What the DPDP Act 2023 requires, and where we stand

The Digital Personal Data Protection Act 2023 is India's data-protection law. The Rules that bring most obligations into force were notified in November 2025 with a phased timeline; the substantive duties on fiduciaries apply from about eighteen months after notification. In practical terms Inventre should be compliant during 2027, and the work below takes months, so it starts now. Confirm the dates with counsel.

Obligation (Act section)	What it means for Inventre	Status	Action
Notice (s.5)	Before or when collecting data, tell the parent in plain language what we collect, why, how to exercise rights and complain.	Done	Privacy notice published at /privacy (v2026-09-24), linked from the footer, login and both consent modals; counsel review pending (P-06)
Consent (s.6)	Free, specific, informed, unambiguous, by clear affirmative action; as easy to withdraw as to give.	Partial	Terms acceptance is recorded (version + time), and the notice version is shown at acceptance. Add a withdrawal path (P-08)

Obligation (Act section)	What it means for Inventre	Status	Action
Legitimate uses (s.7)	Some processing needs no consent: data the parent gives voluntarily for a purpose, legal obligations (GST records), medical emergencies.	Applies	Document which uses rely on this (orders placed voluntarily, tax records)
Security safeguards (s.8(5))	Reasonable measures to prevent breach.	Good	Section 7; P-01 closed, P-02 decided; close P-03, P-16
Breach notification (s.8(6))	Notify the Data Protection Board and each affected parent in the form and time the Rules prescribe (the Rules set 72 hours for the Board's detailed report).	Done	Procedure + templates in docs/runbooks/breach-response.md ; tabletop drill pending (P-09)
Erasure (s.8(7))	Delete personal data when consent is withdrawn or the purpose is served, and make processors delete it too.	Partial	Deletion request path live (account page → tracked concern); automatic anonymisation for inactive parents; other rules count-only (P-04); P-07 processor terms

Obligation (Act section)	What it means for Inventre	Status	Action
Grievance redressal (s.8(10), s.13)	Publish a contact; respond within the period the Rules set.	Partial	Officer block published on /privacy with a 7-working-day target; name pending (P-10); complaints route via the existing concern portal
Accuracy and completeness (s.8(3))	Where data is used to make decisions affecting the person, keep it accurate.	Good	Grade is canonical from the school roster; parents can correct their own details
Children (s.9)	Verifiable parental consent; no tracking, behavioural monitoring or targeted advertising directed at children.	Partial	Section 9; consent basis written into the notice, section 5; P-11
Rights of principals (s.11–14)	Access to a summary of data and processors; correction; erasure; grievance; nomination of a person to act for them.	Partial	Access copy live (Download my data, JSON); erasure request live; correction unchanged (Section 10)
Processors (s.8(2))	Engage processors only under a valid contract.	Partial	P-07

Obligation (Act section)	What it means for Inventre	Status	Action
Significant Data Fiduciary (s.10)	Extra duties (data protection officer, audits, impact assessments) if the government designates a class of fiduciaries as significant.	Not designated	Watch for notifications covering ed-tech or children's data
Penalties (Schedule)	Up to ₹250 crore for failing security safeguards; ₹200 crore for breach-notification and children's-data failures.	—	P-01 and P-09 closed, P-02 decided; P-03 and P-16 next

8.3 Privacy notice: what it must say (outline)

Published at /privacy on 2026-09-24 (version 2026-09-24) following this outline; awaiting counsel review.

- Who we are and how to reach the grievance officer.
- What we collect: parent contact details; child's name, school, grade, sizes; delivery address; order and payment records (never card details); photos you upload for an exchange.
- Why: to show the right school kit, deliver it, invoice it, support you, and, for the fee console, to show the school's fee ledger on its behalf.
- Who else sees it: the fulfilment team (Audit ERP), the payment gateway, the SMS provider, and Microsoft for e-mail and backups.
- How long we keep it: the schedule in Section 6, in one sentence each.
- Your rights: see, correct, delete, complain, nominate; how to do each; that withdrawing consent stops future processing but does not undo past orders we must keep for tax law.
- For children: the parent account is the consent; how a parent removes a child.

09 Children's data

Every student record is a child's record. Section 9 of the Act adds three duties: obtain **verifiable consent of the parent** before processing a child's data, do not **track or behaviourally monitor** children, and do not direct **targeted advertising** at them. Inventre's design already fits well; the consent basis is now written into the notice and the no-tracking test is built; what remains is the per-child consent record.

Requirement	How Inventre meets it today	To do
Verifiable parental consent	Children never log in. The only account is the parent's, verified by a one-time password to the phone the school holds for that parent, and the parent accepts the terms at first login (version and time recorded). Rosters come from the school, which has its own relationship with the parent.	P-11: consent basis now stated in the notice (section 5); per-child consent timestamp NOT built (it would change the child-linking flow; deferred)
No tracking or behavioural monitoring	No analytics or advertising scripts on the storefront; the only client-side storage is the active child, a "seen order status" marker and unsaved drafts; server logs are technical.	Done: an architecture test fails the build if a third-party script tag appears in the storefront layout (P-12, tests/architecture/invariants.test.ts)
No targeted advertising	None exists. Recommendations on the product page are price-nearest, not behavioural.	State it in the notice
Data minimisation for children	Grade, school, sizes and name are needed. Date of birth, student mobile and e-mail are used (account page, ERP payload, admin search); blood group and picture are read only in the admin student editor.	P-05 closed: fields kept with a stated purpose; date of birth scoped to the account page, mobile masked on the public portal

Requirement	How Inventre meets it today	To do
School as the source	Rosters arrive from the school's system or from Excel sheets sent by the school.	P-07: the school agreement should state that the school has the parents' consent to share the roster with Inventre for the kit programme

10 Rights of parents and how we serve them

Right	Today	Target
Access (a summary of the data and the processors)	Done: Account → Your data → Download my data (JSON, all tables keyed by the parent, OTP delivery log without codes). Parents also see their profile, children, addresses, orders and requests in the app.	Add a readable PDF version; the processors list comes from Section 4
Correction	Name, e-mail, phone (with re-verification), addresses and children's sizes are editable. School and grade come from the roster and are corrected through the school or support.	Say so in the notice; support handles roster corrections within the grievance window
Erasure	Request path done: Account → Request account deletion files a tracked concern (sub-type <code>privacy_erasure</code>) to customer care and the audit Help Desk; the anonymisation itself is the retention job.	Switch on the remaining retention rules (P-04) so the request ends in anonymisation (tax records stay, identifiers go)
Withdraw consent	Same path as the deletion request on the account page.	Stops all processing that is not legally required once the retention rules are switched on
Grievance	/privacy publishes the officer block and the 7-working-day target; name to be filled by the owner. Concern portal and support e-mail exist.	P-10: name the officer; tag privacy complaints in the concern portal so they are tracked
Nomination	Not offered.	Add a "nominated contact" field to the parent profile (low priority)

11 Breach response

The operational copy of this procedure, with the Board and parent notification templates, is `docs/runbooks/breach-response.md`. A personal-data breach is any unauthorised access, disclosure, loss or alteration of personal data. This is the procedure; it is short on purpose so it is followed under pressure.

When	Who	Does what
Hour 0	Whoever notices (monitor e-mail, staff, parent, partner)	Tells the owner and it@inventre.in. Nothing is deleted or rebooted before the Engineering lead has taken a snapshot (the 6-hourly snapshot script can be run by hand).
Hour 0–2	Engineering lead	Contains: rotate the affected secret, revoke sessions if needed, block the source, put the maintenance page up if the storefront itself is compromised. Records a timeline in a shared note.
Hour 2–24	Engineering lead + owner	Scopes: which tables, how many families, which children's data, whether photos or fee data are involved. Uses the activity log, server logs and database queries. Decides whether personal data was actually exposed.
Within 72 hours	Owner (or grievance officer)	Notifies the Data Protection Board in the prescribed form with the facts known so far, then the detailed report within the period the Rules set. Keeps counsel informed.
Without undue delay	Owner + operations lead	Notifies each affected parent (SMS or e-mail, in plain language): what happened, what data, what we did, what they should do (for example change their password), whom to contact. Informs the affected schools first.
Within 2 weeks	Engineering lead	Root cause and fixes written up; this document and the HLD register updated; a drill scheduled.

PRECEDENT

The June–July 2026 root compromise was contained (backdoor removed, key-only SSH enforced, watchdogs added, secrets rotated in September). No evidence of data exfiltration was found, but under the Act the same event today would require an assessment against the notification duty. This procedure exists so that assessment is fast and documented next time.

12 Findings and action plan

Ordered by risk. Effort: S under a day, M under a week, L longer. Engineering can do every technical item; the owner's decisions in Section 1 unblock the rest.

ID	Priority	Finding	Action	Effort	Owner
P-01	Closed	OTP codes stored in plain text in <code>otp_logs</code> , forever	Done 2026-09-24: codes sealed with AES-256-GCM (<code>OTP_LOG_KEY</code>), reveal route gated by <code>OTP_REVEAL_PHRASE</code> with a rate limit of 5 per 10 min and an activity-log entry per reveal; legacy codes sealed or nulled by <code>scripts/otp-logs-seal-legacy.ts</code> ; migration 0080; codes wiped after 24 h, rows after 90 days	S	Engineering
P-02	Decided	Parents' exchange and concern photos in a publicly readable bucket	Owner decision 2026-09-24: keep public, unguessable links (the fulfilment ERP opens them directly). Retention rule R5 blanks the photo references 180 days after closure once switched on; objects in the bucket are not deleted yet	M	Owner
P-03	Now	Database password not yet rotated after the 2026 compromise	Owner runs the prepared rotation script	S	Owner

ID	Priority	Finding	Action	Effort	Owner
P-04	Partial	No retention or erasure anywhere	Nightly job live in count-only mode (<code>/api/cron/data-retention</code>); rules R1/R2/R6 (OTP codes, OTP log rows, inactive parents) act automatically; owner approves the rest of Section 6, then <code>RETENTION_APPLY=1</code>	M	Owner then Engineering
P-05	Closed	Sensitive child fields imported (date of birth, blood group, student mobile, picture); v1.0 called them unused	Fields retained with a stated purpose (Section 3); date of birth scoped to the account page (<code>/api/auth/me?include=dob</code>); public portal masks the guardian mobile	S	Engineering
P-06	Closed	No privacy notice	Published at <code>/privacy</code> (v2026-09-24), linked from the footer, login and both consent modals; notice version shown at acceptance. Counsel review is the owner's	M	Owner, counsel
P-07	High	Processor terms missing or informal (Audit ERP, SMS vendor); school agreements silent on roster sharing	Internal data-sharing note with the ERP team; data-processing clause with the SMS vendor; add roster-sharing and fee-processing clauses to school agreements	M	Owner

ID	Priority	Finding	Action	Effort	Owner
P-08	Closed	No self-service access copy or erasure request	Account page: "Download my data" (JSON) and "Request account deletion" (tracked concern, sub-type <code>privacy_erasure</code>); anonymisation itself is the retention job (P-04)	M	Engineering
P-09	Closed	No written breach procedure	Runbook with Board and parent notification templates in <code>docs/runbooks/breach-response.md</code> ; the tabletop drill is the owner's	S	Owner, Engineering
P-10	Partial	No grievance officer	Officer block and 7-working-day target published on /privacy; name pending. Set <code>NEXT_PUBLIC_GRIEVANCE_OFFICER_NAME</code> / <code>NEXT_PUBLIC_GRIEVANCE_OFFICER_EMAIL</code> (baked at build) and redeploy	S	Owner
P-11	Partial	Consent basis for children's data not documented	Basis documented in the notice (section 5) and Section 9; per-child consent timestamp deferred (changes the child-linking flow)	S	Engineering, counsel
P-12	Closed	Nothing prevents a future analytics or advertising script on the storefront	Architecture test in <code>tests/architecture/invariants.test.ts</code> fails the build on a third-party script tag in storefront layouts	S	Engineering

ID	Priority	Finding	Action	Effort	Owner
P-13	Partial	Activity-log diffs carry personal data indefinitely	Retention rule R3 (2 years online) exists in the nightly job, count-only until switched on	S	Engineering
P-14	Partial	Data location of the Microsoft 365 tenant and R2 bucket not confirmed	R2 bucket location hint = APAC (confirmed 2026-09-24); Microsoft 365 tenant region: check the admin centre and record here	S	Engineering
P-15	Closed	Public support portal returned a guardian's full mobile and the child's gender to anyone searching by Student ID	Mobile now masked to the last 4 digits unless the visitor searched by that number	S	Engineering
P-16	High	Concern photo upload on the public portal needs no login; anyone can push files into our bucket	Add a per-IP rate limit and a signed upload ticket issued by the search step	S	Engineering
P-17	Medium	Blocking a parent account does not end an already-open session	Check <code>parents.status</code> in the session resolver	S	Engineering

Sources: production schema `db/schema.ts` and migrations, `server/` code, deployment and backup configuration as of 2026-09-24 (the rectification changes are implemented and awaiting deployment); Digital Personal Data Protection Act 2023 and the DPDP Rules 2025 as generally understood at the date of writing. Legal interpretation to be confirmed by counsel.